

WIRESHARK NSLOOKUP DNS QUERY:

Breve analisi di un DNS query di nslookup con Wireshark.

The screenshot shows two windows. The top window is Wireshark, capturing traffic on eth0. It displays a list of packets with the following details:

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	PCSSystemtec_63:b0:...	Broadcast	ARP	42	Who has 10.0.2.2? Tell 10.0.2.2
2	0.000403779	52:55:0a:00:02:02	PCSSystemtec_63:b0:...	ARP	64	10.0.2.2 is at 52:55:0a:00:02:02
3	0.000412109	10.0.2.15	8.8.8.8	DNS	73	Standard query 0x7009 A www.cisco.com
4	0.022679817	8.8.8.8	10.0.2.15	DNS	271	Standard query response 0x7009 A www.cisco.com
5	0.023309688	10.0.2.15	8.8.8.8	DNS	85	Standard query 0x1744 AAAA www.cisco.com
6	0.048219661	8.8.8.8	10.0.2.15	DNS	141	Standard query response 0x1744 AAAA www.cisco.com

The bottom window is a terminal on kali@kali: ~, showing the execution of nslookup for www.cisco.com:

```
(kali@kali)-[~]
$ nslookup
> www.cisco.com
Server:      8.8.8.8
Address:     8.8.8.8#53

Non-authoritative answer:
www.cisco.com canonical name = www.cisco.com.akadns.net.
www.cisco.com.akadns.net canonical name = wwwds.cisco.com.edgekey.net.
wwwds.cisco.com.edgekey.net canonical name = wwwds.cisco.com.edgekey.net.globalredir.akadns.net.
wwwds.cisco.com.edgekey.net.globalredir.akadns.net canonical name = e2867.dsca.akamaiedge.net.
Name:   e2867.dsca.akamaiedge.net
Address: 184.25.52.119
Name:   e2867.dsca.akamaiedge.net
Address: 2a02:26f0:2d:a81::b33
Name:   e2867.dsca.akamaiedge.net
Address: 2a02:26f0:2d:a96::b33
> exit
```

Avvio cattura wireshark su eth0 con IPv4 dinamico (dhcp) 10.0.2.15/24 (NAT range di virtualbox) e da terminale avvio nslookup e faccio query di dominio www.cisco.com attraverso la mia DNS 8.8.8.8 (Google). Vedremo in dettaglio tutte le informazioni che ci ha restituito esattamente cosa significano. Per ora terminiamo cattura pacchetti e aggiungiamo filtro per protocollo UDP su port 53 (port standard per il Domain Name System DNS)

udp.port==53					
No.	Time	Source	Destination	Protocol	
3	0.000412109	10.0.2.15	8.8.8.8	DNS	
4	0.022679817	8.8.8.8	10.0.2.15	DNS	
5	0.023309688	10.0.2.15	8.8.8.8	DNS	
6	0.048219661	8.8.8.8	10.0.2.15	DNS	

Time	Source	Destination	Protocol	Length	Info
3 0.000412109	10.0.2.15	8.8.8.8	DNS	73	Standard query 0x7009 A www.cisco.com

Andiamo ad analizzare la Standard Query A, il primo passaggio della DNS resolution.

```

> Frame 3: Packet, 73 bytes on wire (584 bits), 73 bytes captured (584 bits) on interface eth0, id 0
> Ethernet II, Src: PCSSystemtec_63:b0:05 (08:00:27:63:b0:05), Dst: 52:55:0a:00:02:02 (52:55:0a:00:02:02)
  > Destination: 52:55:0a:00:02:02 (52:55:0a:00:02:02)
  > Source: PCSSystemtec_63:b0:05 (08:00:27:63:b0:05)
    Type: IPv4 (0x0800)
    [Stream index: 1]
> Internet Protocol Version 4, Src: 10.0.2.15, Dst: 8.8.8.8
> User Datagram Protocol, Src Port: 53475, Dst Port: 53
> Domain Name System (query)

```

Su field Ethernet II vediamo EtherType IPv4, con MAC di destinazione 52:55:0a:00:02:02 che è quello del GATEWAY virtualbox in outbound, mentre l'altro è l'indirizzo MAC dell'interfaccia di rete eth0 di Kali come vedo anche da questo confronto diretto (con comando ip a):

```

Frame 3: Packet, 73 bytes on wire (584 bits), 73 bytes captured (584 bits) on interface eth0, id 0
Ethernet II, Src: PCSSystemtec_63:b0:05 (08:00:27:63:b0:05), Dst: 52:55:0a:00:02:02 (52:55:0a:00:02:02)
  > Destination: 52:55:0a:00:02:02 (52:55:0a:00:02:02)
    ... ..01 = LG bit: Locally administered address (this is NOT t
    ... ..0 = IG bit: Individual address (unicast)
  > Source: PCSSystemtec_63:b0:05 (08:00:27:63:b0:05)
    ... ..0 = LG bit: Globally unique address (factory default)
    ... ..0 = IG bit: Individual address (unicast)
    Type: IPv4 (0x0800)
    [Stream index: 1]
Internet Protocol Version 4, Src: 10.0.2.15, Dst: 8.8.8.8

```

```

$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 85979sec preferred_lft 85979sec

```

In questo caso il MAC address è il gateway virtualbox anziché il MAC del server DNS google 8.8.8.8 in quanto MAC resolution avviene a livello 2 Data Link e opera solo in rete locale.

```

> Internet Protocol Version 4, Src: 10.0.2.15, Dst: 8.8.8.8
  0100 .... = Version: 4
  .... 0101 = Header Length: 20 bytes (5)
  > Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
    Total Length: 59
    Identification: 0x5484 (21636)
  > 0000 .... = Flags: 0x0
    ...0 0000 0000 0000 = Fragment Offset: 0
    Time to Live: 64
    Protocol: UDP (17)
    Header Checksum: 0xa10 [validation disabled]
    [Header checksum status: Unverified]
    Source Address: 10.0.2.15
    Destination Address: 8.8.8.8
    [Stream index: 0]

```

Dal campo Internet Protocol Version 4 (IPv4) come prima cosa vedo la specificazione del protocollo UDP, il source address ovvero l'IP di Kali 10.0.2.15 ed il destination Address della DNS in questo caso quella di Google 8.8.8.8.

Nel campo User Datagram Protocol vediamo il source Port 53475 (port effimero) e Destination Port 53 (default per DNS).

Utilizza port effimero random

per dare un port di ritorno specifico alla sessione dove Google potrà rispondere al query.

UDP è stato scelto in quanto non necessita handshake per efficienza e standard DNS query.

```

> User Datagram Protocol, Src Port: 53475, Dst Port: 53
  Source Port: 53475
  Destination Port: 53
  Length: 39
  Checksum: 0x1c57 [unverified]
  [Checksum Status: Unverified]
  [Stream index: 0]
  [Stream Packet Number: 1]
  > [Timestamps]
    UDP payload (31 bytes)

```

```

Domain Name System (query)
Transaction ID: 0x7009
Flags: 0x0100 Standard query
0... .. = Response: Message is a query
.000 0... .. = Opcode: Standard query (0)
... ..0. .... = Truncated: Message is not truncated
... ..1 .... = Recursion desired: Do query recursively
... ..0... .. = Z: reserved (0)
... ..0 .... = Non-authenticated data: Unacceptable

Questions: 1
Answer RRs: 0
Authority RRs: 0
Additional RRs: 0

Queries
  www.cisco.com: type A, class IN
  [Response In: 4]

```

Nel campo Domain Name System (query) possiamo invece vedere il tipo di query, in questo caso un query recursivo come specificato da Flags.

Query recursivo specifica a server DNS di riportare solo la risposta finale e di non mostrare i “referrals” che sono i server autoritativi “attraversati” per raggiungere i server di www.cisco.com.

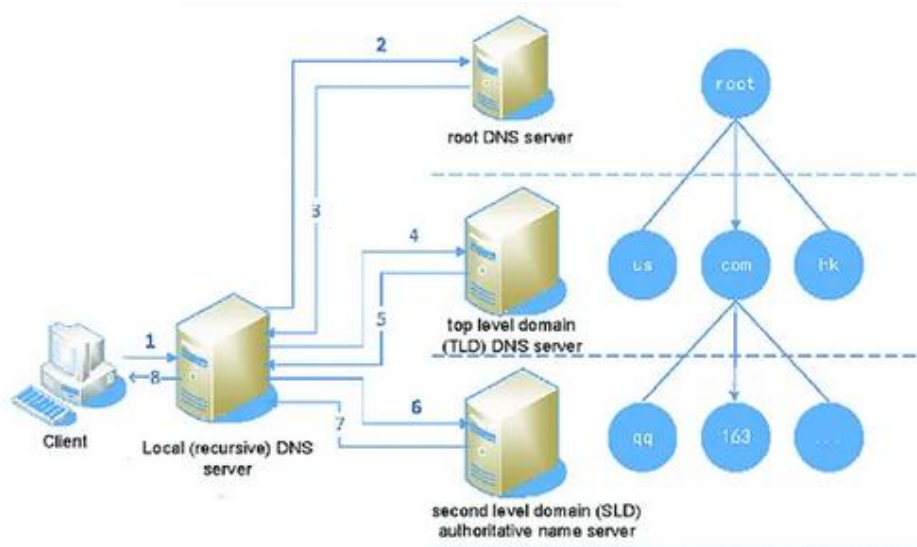
Su “Queries” vediamo appunto il domain name che stiamo chiedendo alla nostra DNS di risolvere, questo è riportato in plaintext nel pacchetto.

```

52 55 0a 00 02 02 08 00 27 63 b0 05 08 00 45 00 RU.....'c....E.
00 3b 54 84 00 00 40 11 0a 10 0a 00 02 0f 08 08 ;T...@.....
08 08 d0 e3 00 35 00 27 1c 57 70 09 01 00 00 01 .....5...'wp....
00 00 00 00 00 00 03 77 77 77 05 63 69 73 63 6f .....w ww.cisco
03 63 6f 6d 00 00 01 00 01 .....com.....

```

Kali eth0 (10.0.2.15/24) → Gateway Virtualbox → Recursive Resolver Google DNS server (8.8.8.8)
→ Referrals → Cisco



Client: Kali | Recursive Resolver: Google DNS | Root DNS server

TLD: Ritornano I Referrals (.COM)| SLD: Cisco servers

```
4 0.022679817 8.8.8.8 10.0.2.15 DNS 271 Standard query response 0x7009 A www.cisco.com
```

Vediamo ora la standard query response A.

```
▼ Ethernet II, Src: 52:55:0a:00:02:02 (52:55:0a:00:02:02), Dst: PCSSystemtec_63:b0:05 (08:00:27:63:b0:05)
  ▼ Destination: PCSSystemtec_63:b0:05 (08:00:27:63:b0:05)
    .... ..0. .... = LG bit: Globally unique address (factory default)
    .... ..0. .... = IG bit: Individual address (unicast)
  ▼ Source: 52:55:0a:00:02:02 (52:55:0a:00:02:02)
    .... ..1. .... = LG bit: Locally administered address (this is NOT the factory default)
    .... ..0. .... = IG bit: Individual address (unicast)
  Type: IPv4 (0x0800)
  [Stream index: 1]
```

Nel field Ethernet II notiamo ora che i MAC address sono invertiti, torna dal nostro gateway verso all'interfaccia eth0 di Kali

```
▼ Domain Name System (response)
  Transaction ID: 0x7009
  ▼ Flags: 0x8180 Standard query response, No error
    1... .. = Response: Message is a response
    .000 0... = Opcode: Standard query (0)
    .... .0.. = Authoritative: Server is not an authority for domain
    .... ..0. = Truncated: Message is not truncated
    .... ...1 = Recursion desired: Do query recursively
    .... ...1 = Recursion available: Server can do recursive queries
    .... ...0. = Z: reserved (0)
    .... ...0. = Answer authenticated: Answer/authority portion was not authenticated by the server
    .... ...0. = Non-authenticated data: Unacceptable
    .... ...0000 = Reply code: No error (0)
  Questions: 1
  Answer RRs: 5
  Authority RRs: 0
```

La Domain Name System (response) ovvero la risposta del DNS google ha nei flag la specifica appunto di risposta, recursiva, e possibilità dei server di rispondere a query recursivi. Nel campo Query notiamo sempre il server www.cisco.com target del query DNS:

```
▼ Queries
  ▶ www.cisco.com: type A, class IN
  ▼ Answers
    ▶ www.cisco.com: type CNAME, class IN, cname www.cisco.com.akadns.net
    ▶ www.cisco.com.akadns.net: type CNAME, class IN, cname wwwds.cisco.com.edgekey.net
    ▶ wwwds.cisco.com.edgekey.net: type CNAME, class IN, cname wwwds.cisco.com.edgekey.net.globalredir.akadns.net
    ▶ wwwds.cisco.com.edgekey.net.globalredir.akadns.net: type CNAME, class IN, cname e2867.dsca.akamaiedge.net
    ▶ e2867.dsca.akamaiedge.net: type A, class IN, addr 184.25.52.119
  [Request In: 3]
  [Time: 22.267708 milliseconds]
```

Per quanto riguarda la risposta stessa nel campo Answers veddiamo che www.cisco.com non abbia un indirizzo IP diretto ma utilizza diversi Alias (type CNAME) che infine utilizzano server akamai CDN con IPv4 184.25.52.119

#ultima osservazione, se rimuovo il filtro UDP noto la normale risoluzione di indirizzi MAC tramite ARP request e ARP reply tra Kali e Gateway

Time	Source	Destination	Protocol	Length	Info
0.000000000	PCSSystemtec_63:b0:...	Broadcast	ARP	42	Who has 10.0.2.2? Tell 10.0.2.15
0.000403779	52:55:0a:00:02:02	PCSSystemtec_63:b0:...	ARP	64	10.0.2.2 is at 52:55:0a:00:02:02

WIRESHARK SNIFFING

Un attaccante potrebbe utilizzare wireshark per intercettare i pacchetti tra noi e servizi web (o meno) che, se utilizzano protocolli non sicuri o trasmettono informazioni sensibili in plaintext, potrebbe portare a esfiltrazione di dati importanti, ricostruzione di network interno, abitudini dell'utente (quando è attivo, su quali siti va, etc...).

Questo è il concetto base del packet sniffing. Esso non è prettamente malizioso in quanto utile anche per monitoraggio di rete su ambienti aziendali, ma può benissimo essere

utilizzato anche da threat actor per ricevere illecitamente informazioni private.

Lo sniffer agisce al di fuori del firewall ed è difficile quindi da rilevare ponendo un serio rischio, è necessario per questo assicurarsi di non tralasciare informazioni private/sensibili o tantomeno credenziali di accesso su siti e servizi non cifrati/crittografati in maniera sicura.

Ma anche in HTTPS come abbiamo visto alcune informazioni viaggiano in plaintext (il sito per cui stavamo facendo il query ad esempio).

Un metodo di mitigazione dei rischi sarebbe usare una VPN che aggiunge un layer di encryption aggiuntivo e nasconde l'IP di origine (anche se comporta routing di tutto il tuo traffico su un singolo servizio VPN che potrebbe per alcuni utilizzi non essere ideale, single point of failure nel caso di un Supply Chain Attack ai loro server).

